

法院自动立案工具方案

05 合规与风控

合规与风控

一、法律法规合规

1.1 核心法规

网络安全法:

- 网络安全等级保护
- 用户信息保护

个人信息保护法:

- 用户明确授权
- 信息删除权

数据安全法:

- 重要数据保护
- 跨境传输限制

电子签名法:

- 身份认证要求
- 时间戳服务

1.2 法院相关规定

人民法院在线诉讼规则:

- 材料提交规范
- 身份核验要求

律师执业规范:

- 保密义务
- 利益冲突

1.3 合规措施

数据收集:

- 获取用户授权
- 提供撤回机制

数据使用:

- 不用于其他商业用途
- 不向第三方提供

数据存储:

- 加密存储
- 定期备份

数据删除:

- 案件结束后保留期限
- 彻底删除机制

二、法院平台合规

2.1 使用规范

- 账号使用:
- 不得共享账号
 - 不得批量注册
- 操作频率:
- 避免高频请求
 - 遵守平台限流
- 行为模拟:
- 正常浏览路径
 - 避免异常模式

2.2 风险规避

- 技术层面:
- 模拟正常用户行为
 - 分散请求时间
- 业务层面:
- 最终确认需人工
 - 保留操作日志

2.3 应急预案

- 账号被封:
- 申诉流程准备
 - 人工接管机制
- 平台改版:
- 快速适配更新
 - 降级人工处理
- 政策变化:
- 及时调整策略
 - 合规审查机制

三、数据安全

3.1 安全架构

+-----+ 应用层安全 - 输入校验 XSS防护 CSRF防护 参数签名
+-----+ 认证授权层 - JWT Token RBAC 双因素认证 会话管理
+-----+ 传输层安全 - TLS 1.3 证书固定 HSTS 防中间人
+-----+ 存储层安全 - AES加密 密钥托管 访问审计 备份加密
+-----+ 基础设施安全 - 防火墙 WAF IDS/IPS 漏洞扫描
+-----+

3.2 加密策略

传输加密:

- HSTS头部
- 证书固定(Pinning)

存储加密:

- 文件AES-256加密
- 密钥KMS托管

字段加密:

- 手机号: 对称加密
- 银行账号: 对称加密

3.3 访问控制

身份认证:

- 手机验证码
- 双因素认证(可选)

权限控制:

- 数据权限(行级)
- 操作权限(按钮级)

会话管理:

- 刷新Token 7天
- 单点登录限制

四、审计与监控

4.1 操作审计

审计范围:

- 案件创建/修改/删除
- 材料上传/下载
- 提交立案操作
- 法院平台操作

审计内容:

- 操作对象/动作
- 变更前后值
- 操作结果

4.2 安全监控

监控指标:

- 异常操作 (批量/非工作时间)
- 数据访问 (越权/大量导出)
- 系统性能 (响应时间/错误率)

告警机制:

- 定时报表 (日常统计)
- 应急通知 (重大事件)

4.3 日志管理

日志分级:

- INFO: 正常操作
- WARN: 警告信息
- ERROR: 错误信息
- FATAL: 严重错误

日志保留:

- 审计日志: 5年
- 安全日志: 永久

五、应急响应

5.1 应急响应流程

发现事件 | 初步评估 (5分钟) | 启动预案 (15分钟) | 处置控制 (1小时) | 恢复验证 (2小时) | 总结改进 (24小时)

5.2 事件分级

P0-紧急:

- 系统不可用
- 法院投诉

P1-重要:

- 性能严重下降
- 安全漏洞

P2-一般:

- 优化建议
- 非紧急bug

5.3 联系方式

内部:

- 技术负责人: xxx
- 法务负责人: xxx

外部:

- 安全厂商: 应急响应
- 律师事务所: 法律顾问